

Lectura 9 — IC-7602 Redes

Estudiante: Joshua Obando Castro **Carné:** 2023130774

Fecha: 2026-05-22 **Profesor:** Nereo Campos

1. ¿Qué es un firewall? Tipos existentes en capa 3/4

Un firewall es un sistema que se posiciona entre la red interna de una organización y el mundo exterior. Su función principal es doble: por un lado controla qué máquinas y servicios son visibles para un agente externo, y por otro controla qué pueden ver y usar los usuarios internos cuando acceden a Internet. La forma en que lo hace es inspeccionando cada paquete que pasa por el router gateway, lo que hace que estos sistemas sean conocidos también como sistemas de filtración de paquetes.

Es importante entender desde el inicio que un firewall no es una solución perfecta ni completa por sí sola. Su fortaleza depende directamente de las políticas de acceso que se definan y de la consistencia con que se mantengan actualizadas, ya que cambios frecuentes en la red pueden requerir reconfigurar el gateway completo, lo que si se hace mal puede dejar la red expuesta.

1.1 Packet filtering routers

Los routers y computadoras que hacen filtración de paquetes toman decisiones de enrutamiento basándose en una tabla de reglas predefinida. Lo relevante aquí es que el router no mira el contenido del payload del paquete sino únicamente el encabezado TCP/IP, evaluando de dónde viene el paquete y hacia dónde va. Si el paquete coincide con un conjunto de parámetros definidos en la tabla, el router decide si lo permite o lo bloquea.

Este tipo de firewall puede operar en dos formas. La primera es una red abierta con filtrado selectivo de tráfico no deseado, donde por cada tipo de ataque conocido se debe configurar un filtro específico en el router. La segunda es una red cerrada con filtrado selectivo de tráfico permitido, que es más segura ya que bloquea todo por defecto y solo deja pasar lo explícitamente autorizado, aunque tiene la desventaja de que hay que actualizarla cada vez que se agrega un servicio o computadora nueva.

Una limitación importante de este esquema es que no hay forma de hacer autenticación de usuario. La decisión se toma a nivel de par de direcciones IP, entonces o se permite el tráfico entre dos máquinas o no, sin ninguna granularidad de quién es el usuario que está detrás de esa máquina. Aparte de eso, cambios frecuentes en la red pueden requerir reconfigurar el router completo, lo que puede ser costoso en tiempo y propenso a errores.

2. ¿Qué es un bastion host?

Un bastion host, también llamado screening host, combina el mecanismo de filtrado de paquetes del router con un host asegurado. Un host asegurado es una máquina que ha tenido su sistema operativo y servicios principales revisados y endurecidos por un experto en seguridad. La idea es que el router de filtrado proporciona la primera línea de defensa controlando qué tráfico entra y sale, mientras que el bastion host actúa como un punto intermedio que controla el flujo de información en ambas direcciones.

El bastion host está conectado a Internet de la misma forma que cualquier otra máquina de la red, pero el gateway permite que el tráfico le llegue con menos restricciones que al resto. La política de seguridad del sitio es la que dicta qué se configura en el router de filtrado, y una ventaja importante es que la configuración del filtro se vuelve una declaración genérica de "denegar todo" seguida de declaraciones muy específicas de lo que sí se permite llegar al bastion host, lo que reduce la carga del personal de seguridad ya que agregar nuevas máquinas o que usuarios instalen equipos mal configurados no afecta el firewall.

Sin embargo, tener un punto centralizado de control tiene sus desventajas. En redes grandes y muy activas se necesitan varios bastion hosts para evitar congestión, y cada uno requiere su propia sección en el firewall de filtrado de paquetes, lo que incrementa la complejidad y el esfuerzo de pruebas. Además, al centralizar la información en el bastion host, este se convierte en un objetivo prioritario para los atacantes, ya que obtener privilegios de operador del sistema en él representaría un riesgo de seguridad enorme. Esto lo hace un único punto de falla.

3. ¿En qué consiste una DMZ?

Una DMZ, que viene del término "demilitarized zone" o zona desmilitarizada, es una red perimetral que sirve como zona tampón entre la red interna de una organización y el exterior hostil, en este caso Internet. La analogía es exactamente la de un área de amortiguamiento entre dos partes que coexisten en proximidad. Su objetivo es agregar capas adicionales de seguridad más allá del simple filtrado de paquetes.

En una DMZ estándar participan al menos dos routers. Uno se ubica como gateway hacia Internet y otro como gateway hacia la red interna. La red que comparten estos dos routers, es decir la DMZ, no debe tener ningún equipo que no sea de enrutamiento o bastion hosts de confianza. Esto tiene una implicación de seguridad importante: si un intruso logra comprometer algo en la red perimetral, solo puede ver los paquetes que transitan por ella, nada más. Para llegar a la red interna tendría que comprometer también el router interior, lo que representa una barrera adicional significativa.

Los controles más estrictos y cuidadosos en una construcción de zona perimetral se colocan en el router interior, que es el que separa la red interna de la DMZ y del exterior. Esta configuración se puede visualizar como círculos concéntricos donde cada capa hacia afuera provee menos seguridad. También es común usar Network Address Translation (NAT) en el router interior para traducir las direcciones no enrutables de la red interna como el rango 192.168.0.0 a direcciones de Internet reales de forma dinámica, lo que dificulta aún más que un atacante localice y comprometa los hosts internos.

La configuración de mayor seguridad posible en una DMZ es deshabilitar todo el tráfico saliente desde la red interna hacia el router exterior, y todo el tráfico entrante desde Internet hacia la red interna. Esto convierte el proceso en dos pasos forzosos: los clientes de Internet solo pueden comunicarse con las máquinas en la red perimetral, y los clientes de la red interna tampoco pueden ver Internet directamente, sino que deben hacerlo a través de un intermediario como un bastion host en la DMZ.

4. ¿Qué es un proxy server?

Un proxy server es similar en concepto a un bastion host, al punto que en muchos textos de seguridad los dos se traslapan casi completamente. La distinción está en el enfoque: el bastion host se usa como área de staging de información en tránsito hacia o desde Internet, mientras que el proxy server es un tipo de bastion

host que corre software especializado que hace que una máquina interna se enmascare como si fuera una externa.

Una buena ilustración es el caso del correo electrónico. Un bastion host típicamente actúa como el punto de entrega del correo entrante desde Internet, donde el registro MX del DNS apunta al bastion para la entrega, y desde ahí el bastion puede reenviar el correo al servidor interno de correo o retenerlo para que el cliente lo lea con un cliente POP. Un proxy en cambio es más un punto de tránsito, donde el servicio pretende ser uno de los extremos de una conexión para proteger el origen o destino real del tráfico no deseado.

El protocolo que más problemas genera para un administrador de seguridad es FTP, ya que usa puertos altos y aleatorios para establecer sesiones peer-to-peer, lo que lo hace difícil de controlar con filtrado simple. La solución es el modo pasivo de FTP que usa los puertos 20 y 21 para el control y la transferencia de datos, aunque no todos los clientes lo soportan. Al usar un proxy FTP en la red perimetral, el proxy actúa como cliente hacia el servidor FTP externo y el software especial instalado en el proxy acepta las solicitudes entrantes del cliente FTP real que está en la red interna.

Es importante no considerar un proxy como una solución total de seguridad sino como una medida adicional de protección. El firewall de filtrado de paquetes sigue siendo fundamental y el proxy se complementa con él para aislar unidades de alto riesgo de las de bajo riesgo.

5. Protocolos de VPN

Una VPN no se sostiene solo con firewalls. Una vez que el tráfico entra a la red desde el exterior, los mecanismos de autenticación y encriptación son los que garantizan que la comunicación sea segura y que los participantes sean quienes dicen ser.

5.1 IPSec

IPSec es un protocolo genérico creado y mantenido por el IETF para proveer servicios de seguridad al protocolo IP, tanto para IPv4 como para IPv6. Su diseño es modular y orientado a componentes, lo que significa que no prescribe algoritmos de encriptación o intercambio de llaves específicos, sino que define la estructura que los contiene, haciendo que sea posible agregar nuevos algoritmos con poco impacto en implementaciones anteriores.

La idea central de IPSec es asegurar la red misma sin requerir cambios en las aplicaciones que corren sobre ella. Dado que TCP/IP es ubicuo, tiene sentido construir la seguridad ahí. IPSec soporta dos modos de encriptación: el modo transporte, que protege solo el payload de cada paquete, y el modo túnel, que encripta tanto el encabezado como el payload, siendo este último más seguro ya que protege la identidad del emisor y receptor.

Los tres componentes principales de IPSec son los algoritmos de encriptación, los algoritmos de autenticación y el manejo de llaves. Entre sus beneficios están mayor seguridad e interoperabilidad con otros productos IPSec, ya que todos usan los mismos algoritmos de autenticación, intercambio de llaves y encriptación más robustos.

5.2 ESP (Encapsulating Security Payload)

ESP es la unidad fundamental de transmisión dentro de IPSec. Fue diseñado para soportar casi cualquier tipo de encriptación simétrica como DES o triple DES, y actualmente depende mínimamente de DES de 56 bits.

ESP encripta el payload al nivel del datagrama IP usando un nuevo protocolo, y puede encapsularse dentro de otro paquete IP estándar, lo que lo hace compatible con infraestructura de red existente y le permite viajar por canales IP regulares sin que los routers intermedios necesiten entenderlo.

5.3 AH (Authentication Header)

Donde ESP se encarga de la encriptación, AH se encarga de la autenticación sin confidencialidad. AH maneja la seguridad del encabezado IP, mientras que ESP se ocupa del payload. Pueden usarse juntos en modo túnel, o AH puede funcionar como autenticador independiente. Para su funcionalidad base, IPSec requiere que AH implemente HMAC-SHA y HMAC-MD5, que son sistemas de autenticación simétrica basados en esos hashes.

5.4 IKE, ISAKMP/Oakley

En el mundo de IPSec, una Security Association es cualquier conversación protegida entre dos partes potencialmente hostiles. Tener ESP y AH no es suficiente por sí solo para un sistema IPSec completo, ya que ambas partes también necesitan negociar qué algoritmos de encriptación y autenticación van a usar mientras la comunicación está en curso. Ese rol lo cumple el Internet Key Exchange (IKE), anteriormente conocido como ISAKMP/Oakley, que autentica a todos los participantes, maneja las políticas de seguridad que cada uno puede ejecutar y controla el intercambio de llaves.

La generación y rotación de llaves es crítica porque mientras más tiempo se use la misma llave, mayor es la cantidad de datos en riesgo y más fácil es para un atacante acumular ciphertext para analizar. Esto se conoce como el concepto de perfect forward secrecy: cambiar las llaves frecuentemente hace que aunque un atacante logre crackear una, no pueda reconstruir el historial de conversaciones. IKE usa el protocolo de intercambio de llaves Diffie-Hellman para generar llaves que no guarden ninguna semejanza entre sí y que no estén basadas en variables ambientales predecibles como la hora del día o la carga del servidor.

5.5 X.509 v.3 (Certificados Digitales)

X.509 no es un protocolo de seguridad en el mismo sentido que ESP o AH, sino que provee control de acceso a mayor escala. Los sistemas de certificados X.509 se usan junto con dispositivos y software de PKI, y los vendedores de IPSec los han incorporado para manejar autenticación. La gestión de certificados por parte de un tercero de confianza juega un rol importante en el futuro del suite IPSec, y los vendedores ya están trabajando para que sus productos se comuniquen con los Certificate Authorities públicos para autenticación.

5.6 LDAP

LDAP es un servicio X.500 más pequeño y fácil de implementar, que se soporta en varias soluciones VPN para proveer autenticación y gestión de certificados. Productos de hardware como el Bay Networks Extranet Switch y soluciones de software como Windows NT y Novell usan LDAP. Es cada vez más común usar sistemas de autenticación de terceros de confianza como LDAP y el directorio X.500 para acceso remoto a redes corporativas o VPNs.

5.7 Radius

Donde LDAP y X.500 proveen autenticación y gestión de certificados para usuarios en cualquier parte del mundo, Radius es un sistema de autenticación enfocado más en lookups dentro de una organización. Fue desarrollado como estándar abierto por Livingstone Enterprises y no está formalmente avalado por el IETF

aunque está bajo consideración. Más soluciones VPN soportan autenticación con Radius que con los otros sistemas de certificados públicos mencionados.

5.8 PPTP (Point-to-Point Tunneling Protocol)

PPTP es una extensión del protocolo PPP (Point-to-Point) estándar. Sus servicios de tunneling están diseñados para correr sobre la capa IP, mientras que el PPP tradicional opera por debajo de ella. PPP ya tenía la funcionalidad que imitaría una VPN, lo único que le faltaba era la seguridad. PPTP sin embargo está más orientado a comunicaciones host-a-host seguras que a comunicaciones LAN-a-LAN, aunque técnicamente es posible routear tráfico a través de un túnel PPTP. Para el caso de conectar redes completas, las soluciones IPSec son más adecuadas.